

AI Governance — 12 points à vérifier avant de déployer

L'EU AI Act n'attend pas que vous soyez prêt. Vos modèles sont déjà en prod ; voici les 12 contrôles qui décident si vous y restez — ou si vous en sortez avec une amende.



Tout le monde a déployé de l'IA. Presque personne ne l'a gouvernée.

Ces trois dernières années, j'ai vu la même scène se répéter : des dizaines de modèles et d'agents partis en production dans l'enthousiasme, et le jour où quelqu'un demande « qui est responsable de cette IA ? quelles données l'ont entraînée ? peut-on l'arrêter ? » — silence.

Ce n'est la faute de personne. L'IA est allée plus vite que les organisations. Mais le régulateur, lui, a rattrapé son retard : l'EU AI Act est là, ses premières obligations sont déjà en vigueur, et les sanctions se chiffrent en millions d'euros ou en pourcentage du chiffre d'affaires.

La bonne nouvelle : la gouvernance de l'IA n'est pas une montagne. C'est une liste finie de contrôles, dont la plupart relèvent du bon sens organisé — savoir ce qu'on a, documenter ce qu'on fait, surveiller ce qui tourne, pouvoir l'arrêter.

Ce document les résume en 12 points. Ils viennent du terrain : je les applique chez mes clients, sur des systèmes réels, utilisés chaque jour par des centaines de personnes. Pas de théorie — ce qui marche.

Comment l'utiliser : parcourez les 12 points (page 3), cochez ceux que vous couvrez déjà, comptez votre score (page 4). En 30 minutes, vous saurez où vous en êtes — et par quoi commencer.



Les 12 contrôles. Cochez, ou corrigez.

01

[CRITIQUE]

Classification des risques EU AI Act

La loi classe chaque IA selon son niveau de risque : minimal, limité, élevé ou interdit. Plus le risque est élevé, plus vos obligations sont lourdes. IA de recrutement, de scoring ou biométrique = risque élevé. Tout part de là.

✓ Art. 5 & 6, Annexes II & III EU AI Act

02

[CRITIQUE]

Registre IA & Shadow AI

Le test : pouvez-vous lister toutes les IA utilisées chez vous en une heure ? Y compris ChatGPT ou Copilot que vos équipes utilisent sans autorisation (le « shadow AI ») ? On ne peut pas contrôler ce qu'on ne voit pas.

✓ Registre auditable + politique d'usage IA

03

[STRATÉGIQUE]

Un responsable, des équipes formées

Nommez un responsable de la gouvernance IA — sans propriétaire, rien ne se passe. Formez vos équipes aux bases de l'IA (c'est déjà une obligation légale). Et prévoyez comment retirer proprement une IA devenue obsolète.

✓ Art. 4 + ISO 42001 + NIST AI RMF Govern

04

[CRITIQUE]

Qualité & classification des données

Une IA nourrie de mauvaises données donne de mauvaises réponses ; nourrie de données illégales, elle devient illégale. Vérifiez : données licites, représentatives, documentées. Et jamais de donnée confidentielle dans un outil IA non validé pour ça.

✓ Art. 10 EU AI Act + RGPD Art. 5

05

[CRITIQUE]

RGPD & données personnelles

L'AI Act ne remplace pas le RGPD : les deux s'appliquent en même temps. Si votre IA traite des données personnelles, une analyse d'impact (DPIA) est souvent obligatoire — sans elle, arrêtez tout. En cas d'incident, deux délais courent : 72 h (RGPD) et 15 jours (AI Act).

✓ RGPD Art. 22 & 35 + AI Act Art. 73 & 86 + CNIL

06

[OBLIGATOIRE]

Documentation technique

Chaque IA à risque élevé doit avoir sa fiche d'identité (« model card ») : quelles données l'ont entraînée, ses performances, ses défauts connus, ses limites. C'est le premier document qu'un auditeur demande. À conserver 10 ans.

✓ Art. 11 & 13 EU AI Act (Annex IV)

07

[OBLIGATOIRE]

Tests avant mise en production

Avant de déployer, prouvez que votre IA fonctionne pour tout le monde : mesurez ses taux d'erreur sur chaque groupe d'utilisateurs, et gardez la trace écrite. Secteur public, crédit, assurance : une étude d'impact sur les droits fondamentaux (FRIA) est en plus obligatoire.

✓ Art. 9, 15 & 27 EU AI Act

08

[OBLIGATOIRE]

Transparence utilisateurs

Un chatbot qui se fait passer pour un humain, c'est une infraction. L'utilisateur doit savoir qu'il parle à une IA, au moment où il lui parle. Idem pour les images et vidéos générées : elles doivent être marquées comme telles.

✓ Art. 50 EU AI Act — en vigueur août 2026

09

[OBLIGATOIRE]

Sécurité & fournisseurs d'IA

Une IA peut être attaquée : instructions cachées dans un message (prompt injection), données d'entraînement empoisonnées... Faites-la tester par des experts sécurité. Et pour chaque outil IA acheté : que fait le fournisseur de vos données ? Les garde-t-il ? S'en sert-il pour entraîner ses modèles ?

✓ Art. 15 + NIST AI RMF + ISO 27001

10

[OBLIGATOIRE]

Traçabilité & gestion des incidents

Enregistrez automatiquement chaque décision de l'IA : la question posée, la réponse donnée, le modèle utilisé, la date. Sans cette trace, impossible de vous défendre le jour d'un audit ou d'un litige. Et toute modification de l'IA doit déclencher une re-vérification.

✓ Art. 12, 72 & 73 + NIST AI RMF Manage

11

[CRITIQUE]

Surveillance continue en production

Une IA correcte au lancement se dégrade avec le temps : ses réponses dérivent, des biais apparaissent. Il faut la surveiller en continu, avec des alertes envoyées à une équipe capable de corriger — pas à une boîte mail que personne ne lit.

✓ Art. 12, 15 & 72 · Fairlearn, Vertex Monitoring

12

[OBLIGATOIRE]

Contrôle humain & kill-switch

Trois questions : qui peut débrancher votre IA ? En combien de temps ? L'a-t-il déjà testé en réel ? Si la réponse hésite, vous n'avez pas de contrôle humain — vous avez un pilote automatique sans bouton d'arrêt.

✓ Art. 14 EU AI Act

Les 12 points suivent la vie de votre IA

Un projet IA passe toujours par les 5 mêmes étapes. À chaque étape, certains points de la checklist s'appliquent — la gouvernance n'est pas une étape finale, elle accompagne tout le parcours.

1.	Cadrer le projet	Avant d'écrire une ligne de code : quel niveau de risque, qui est responsable, quelles IA existent déjà ?	points 01 · 02 · 03
2.	Préparer les données	Ce qui nourrit l'IA : des données propres, licites, et conformes au RGPD.	points 04 · 05
3.	Construire & tester	Documenter le modèle et prouver qu'il fonctionne pour tous, avant la mise en service.	points 06 · 07
4.	Mettre en service	Informar les utilisateurs qu'ils parlent à une IA, sécuriser le système, tracer chaque décision.	points 08 · 09 · 10
5.	Surveiller au quotidien	Une fois en service : surveiller les dérives, garder un humain aux commandes, pouvoir arrêter.	points 11 · 12

[VOTRE SCORE – COMPTEZ VOS ✓ SUR 12]

0 – 4 ZONE ROUGE Vous déployez sans filet. Commencez par les points 01, 02 et 05 — cette semaine, pas ce trimestre.	5 – 8 EN CHANTIER Les fondations existent, les trous aussi. Listez ce qui manque et avancez : un point réglé par mois.	9 – 12 SOLIDE Vous êtes en avance sur le marché. Prochain cap : automatiser ces contrôles et viser la certification ISO 42001.
--	---	---

SI VOUS NE FAITES QUE 3 CHOSES :

- **01.** Classifiez vos risques et détectez le shadow AI (points 01 & 02)
- **02.** Construisez votre registre IA + politique d'usage (point 02)
- **03.** Mettez du monitoring + kill-switch en prod (points 11 & 12)

LE RESTE S'ENCHAÎNE NATURELLEMENT.

[SANCTIONS EU AI ACT]

Risque inacceptable : interdiction + **35 M€ ou 7 % CA**

Risque élevé non conforme : **15 M€ ou 3 % CA**

Autres infractions : **7 M€ ou 1 % CA**

[DEADLINES EU AI ACT]

Pratiques interdites (Art. 5) : **fév. 2025 ✓**

AI Literacy (Art. 4) : **fév. 2025 ✓**

GPAI (Art. 53) : **août 2025 ✓**

Transparence (Art. 50) : **août 2026**

Risque élevé Annex III : **déc. 2027** · Annex I : **août 2028**

Vous avez la checklist. Maintenant, passez à l'action.

01

Auto-audit

Passez vos systèmes existants au crible des 12 points. Vous saurez où vous en êtes.

→ 1 à 2 jours

02

Cadrage

30 min avec moi : on trie ce qui brûle, ce qui attend, ce qui ne vous concerne pas.

→ **gratuit**

03

Mise en conformité

3 à 6 mois pour tout mettre en place : registre, documentation, monitoring, audits. Je build avec vos équipes.

→ mission régie

→ [reserver_30_min\(\) · calendly.com/renaudsecq/30min](https://calendar.google.com/calendar/invite?res=server_30_min()&calendly.com/renaudsecq/30min)

Renaud Secq

Consultant Freelance IA & Data — Builder & Strategist

20 ans dans le digital. 8 ans freelance grands comptes.

Data Governance → AI Governance → Software Engineering 3.0.

Missions chez Decathlon, Adeo, Auchan, Oney, La Redoute.

renaudsecq.com · linkedin.com/in/renaud-secq · [@renaudsecq](https://twitter.com/renaudsecq)